CRYPTOGRAPHIC PASSWORD HASH SECURITY AUDIT

ENTERPRISE AUTHENTICATION VULNERABILITY ASSESSMENT

Client: Omar Abu Saeed - Security Assessment | Report ID: AUD-59036D4F
Standards: NIST SP 800-63B, OWASP Top 10, RFC 9106, CIS Benchmarks v8.0
Assessment Date: October 31, 2026 | Lead Assessor: Principal Cryptographic Assessor

1. EXECUTIVE EVALUATION SUMMARY

HashSentinel performed an architectural cryptographic evaluation of password hash resilience and authentication mechanisms for Omar Abu Saeed - Security Assessment. The audit benchmarks algorithm execution latency, measures resistance against adversary GPU clusters (8x NVIDIA RTX 4090), and assesses alignment with NIST SP 800-63B Digital Identity Guidelines and OWASP Authentication Cheat Sheet recommendations. No user credentials were submitted during this session; findings reflect baseline infrastructure analysis.

CREDENTIALS TESTED:	VULNERABILITIES:	AVG. ENTROPY:	AVG. STRENGTH:
0	0 Critical	0.0 bits	0%

3. CRYPTOGRAPHIC ALGORITHM BENCHMARK & HARDWARE RESISTANCE

This section benchmarks host-side execution latency for each hashing algorithm and projects cracking feasibility against an adversary equipped with 8x NVIDIA RTX 4090 GPUs (approximately 300 billion MD5 guesses/second). Adaptive algorithms like bcrypt and Argon2id introduce deliberate computational cost that renders brute-force attacks infeasible.

Algorithm	Compute Latency	Digest	Salt	Cracking (8x 4090)	Security Posture
MD5	0.001 ms/hash	32 chars	None	Instant (< 1 ms)	CRITICAL
SHA-1	0.002 ms/hash	40 chars	None	Instant (< 5 ms)	CRITICAL
SHA-256	0.003 ms/hash	64 chars	None	Minutes to Hours	UNSAFE
SHA-512	0.004 ms/hash	128 chars	None	Hours to Days	UNSAFE
BCRYPT	354.120 ms/hash	60 chars	128-bit	Decades (Adaptive)	RECOMMENDED
ARGON2ID	285.400 ms/hash	97 chars	128-bit	Centuries (Mem-Hard)	GOLD STANDARD

4. STRATEGIC REMEDIATION & MITIGATION ROADMAP

The following phased remediation plan addresses identified vulnerabilities in order of criticality. Each phase includes specific technical actions, compliance references, and expected outcomes. Organizations should treat Phase 1 actions as emergency measures and complete them within the first two weeks of receiving this report.

PHASE 1: IMMEDIATE CONTAINMENT (DAYS 0 - 14)

1. Personal Identifier Blacklist: Deploy an active dictionary filter that rejects passwords containing employee names, usernames, organization names, and common corporate terms during registration and password change flows. Ref: NIST SP 800-63B Sec.5.1.1.2.
2. Breach Corpus Screening: Integrate HaveIBeenPwned Pwned Passwords API using the K-Anonymity model (SHA-1 prefix range query) to reject any password appearing in known breach databases without transmitting plaintext credentials over the network.
3. Emergency Credential Rotation: Force immediate password resets for all accounts whose credentials scored below 40% strength or appeared in breach databases. Notify affected users with clear guidance on creating strong passphrases.
4. Audit Logging: Enable detailed authentication event logging (success, failure, lockout, reset) with timestamps, source IP, user agent, and geolocation for forensic analysis.

PHASE 2: ARCHITECTURAL HARDENING & KDF UPGRADE (DAYS 15 - 60)

1. Argon2id Migration: Transition all credential storage from legacy algorithms (MD5, SHA-1, SHA-256) to Argon2id (RFC 9106) with parameters: memory cost 64 MB, time cost 3 iterations, parallelism 1. Implement transparent on-login re-hashing for gradual migration.
2. bcrypt Fallback: Where Argon2id is not supported by the platform, deploy bcrypt with a minimum cost factor of 12 (producing ~250ms latency per hash), ensuring unique per-user 128-bit random salts are generated via CSPRNG.
3. NIST SP 800-63B Policy Alignment: Remove periodic password expiration requirements (which encourage predictable patterns like 'Password1!' to 'Password2!'). Set minimum length to 14 characters. Allow passphrases up to 128 characters. Remove composition rules.
4. Application-Layer Peppering: Store a 256-bit HMAC secret key in a hardware security module (HSM) or secrets manager, separate from the credential database. Apply HMAC-SHA256 pepper before feeding passwords to the KDF.
5. Credential Stuffing Defense: Deploy account lockout after 10 consecutive failures with exponential backoff (30s, 60s, 120s, 300s). Implement IP-based velocity rate limiting.

PHASE 3: ZERO-TRUST ACCESS & DEFENSE-IN-DEPTH (DAYS 61 - 90+)

1. FIDO2 / WebAuthn MFA: Deploy passwordless or multi-factor authentication using hardware security keys (YubiKey, Titan) or platform authenticators (Windows Hello, Touch ID) across all administrative, privileged, and customer-facing authentication endpoints.
2. TOTP Fallback: For users without FIDO2 devices, enforce RFC 6238 TOTP-based authenticator apps (Google Authenticator, Authy, Microsoft Authenticator) as a mandatory second factor. Disable SMS-based OTP due to SIM-swapping vulnerabilities.
3. Continuous Threat Monitoring: Deploy SIEM integration to monitor failed authentication velocity, impossible travel scenarios, credential reuse across services, and anomalous access patterns. Set alert thresholds for >5 failures/minute per account.
4. Secret Rotation Schedule: Implement automated rotation of application pepper keys, API tokens, and service account credentials on a 90-day cycle with zero-downtime deployment.
5. Penetration Testing: Conduct quarterly internal/external password spraying and credential stuffing assessments to validate the effectiveness of implemented controls.

5. COMPLIANCE REFERENCE MATRIX

The following table maps each remediation action to the relevant industry standards and regulatory frameworks to support compliance and audit readiness.

Control / Action	NIST SP 800-63B	OWASP ASVS	CIS Controls	PCI DSS 4.0
Argon2id / bcrypt adoption	Sec.5.1.1.2	V2.4.4	5.2	Req 8.3.2
Breach database screening	Sec.5.1.1.2	V2.1.7	16.1	Req 8.3.6
Personal name blacklist	Sec.5.1.1.2	V2.1.8	16.1	Req 8.3.6
14-char minimum length	Sec.5.1.1.1	V2.1.1	5.2	Req 8.3.1
Remove periodic expiry	Sec.5.1.1.2	V2.1.10	5.2	N/A
Multi-factor authentication	Sec.4.2.1	V2.8.1	6.3	Req 8.4.2
Rate limiting / lockout	Sec.5.2.2	V2.2.1	16.11	Req 8.3.4
Audit logging	Sec.4.3.4	V7.1.1	8.5	Req 10.2

6. RECOMMENDED PASSWORD POLICY CONFIGURATION

Based on the assessment findings and current NIST SP 800-63B guidance, the following password policy parameters are recommended for immediate implementation:

Policy Parameter	Current (Typical)	Recommended	Priority
Minimum password length	8 characters	14 characters	CRITICAL
Maximum password length	64 characters	128 characters	HIGH
Hashing algorithm	SHA-256 / MD5	Argon2id (RFC 9106)	CRITICAL
Salt generation	None / static	128-bit CSPRNG/user	CRITICAL
Work factor (bcrypt)	Cost 4-8	Cost 12+	HIGH
Periodic expiration	60-90 days	Remove (event-based)	MEDIUM
Breach database check	Disabled	HIBP K-Anonymity	CRITICAL
Personal name filter	Disabled	Active dictionary	HIGH
MFA requirement	Optional	Mandatory (FIDO2)	HIGH
Account lockout	3 attempts	10 + exponential backoff	MEDIUM

7. TECHNICAL REFERENCES & FURTHER READING

- NIST SP 800-63B: Digital Identity Guidelines - Authentication and Lifecycle Management (June 2017, Updated 2024)
- RFC 9106: Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications (Sept 2021)
- OWASP Authentication Cheat Sheet - Password Storage, Credential Stuffing Prevention (2024 Edition)
- OWASP Application Security Verification Standard (ASVS) v4.0.3 - Chapter V2: Authentication
- CIS Controls v8.0 - Control 5: Account Management, Control 6: Access Control Management
- PCI DSS v4.0 - Requirement 8: Identify Users and Authenticate Access to System Components
- FIDO Alliance WebAuthn Specification - W3C Recommendation Level 2 (April 2021)
- HaveIBeenPwned API v3 - K-Anonymity Model for Pwned Passwords (Troy Hunt, 2024)
- Password Hashing Competition (PHC) - Final Report and Winner Selection (2015)

8. FORMAL COMPLIANCE ATTESTATION & SIGN-OFF

LEAD CRYPTOGRAPHIC ASSESSOR:

Principal Cryptographic Assessor

Date: October 31, 2026

REPORT VERIFICATION CHECKSUM (SHA-256):

`d826a46bc9d6288111af978eb12424e06bdae812`

Report ID: AUD-59036D4F

Attestation: This security assessment report was generated by HashSentinel Enterprise Suite under authorized scope for the named client. All credential testing was performed in an isolated environment using one-way hash computations. No plaintext passwords were stored, transmitted, or retained beyond the active session. Data handling complies with responsible security disclosure principles, GDPR data minimization requirements, and client NDA obligations.

DISCLAIMER: This report is provided for informational and educational purposes as part of a security assessment engagement. The findings and recommendations are based on data available at the time of assessment and may not reflect the current security posture if changes have been made since the assessment date. HashSentinel and its assessors assume no liability for actions taken or not taken based on this report. Recipients are advised to consult qualified security professionals before implementing changes to production authentication systems.